{EPITECH}

AREA_

< SECURITY EVIDENCE />

AREA

Security work must be demonstrated, not only described. When a selected **SEC** feature makes a security claim, your group must be able to reproduce the relevant scenario and show the evidence that supports the claim.

This document is intentionally lightweight. It is a suggested structure for the evidence attached to your selected **SEC** features, not a request for a long audit report.

Evidence entry

For each selected **SEC** feature, record the following information.

Feature

- ✓ Identifier of the feature: `SEC-...`
- ✓ Security claim being demonstrated:

Attack scenario

Describe the concrete scenario being tested:

- ✓ what the attacker can do, and where they start from;
- ✓ the target or asset at risk;
- ✓ the action performed;
- ✓ the expected impact if the protection did not exist.

The scenario must be reproducible by an evaluator without relying on an undocumented manual setup.

Reproduction

Provide the shortest reproducible procedure: a command, a request, a script, a test case or a sequence of actions.

Do not include real credentials, tokens or personal data in the evidence.

Observed evidence

Record what proves that the scenario was exercised: the relevant response, a test result, a sanitized log entry, a screenshot, a trace or any other observable artifact.

An assertion such as ”the application is protected against SSRF” is not evidence by itself.

Protection

Explain which mechanism prevents, limits or detects the attack, and where it is implemented.

Verification

Run the attack scenario again against the protected product and record the observable result. The evidence must make it possible to distinguish the attempted attack from a scenario that was never executed.

Limits

State what the demonstrated protection does **not** cover, including its assumptions and the known residual risks.

Defense principle

The evaluator may select one security claim from this evidence and ask your group to reproduce it live. A claim that cannot be reproduced is not considered demonstrated.

The reasoning expected is the one you exercised in your security projects: attack scenario, observation, protection, verification. Not a checklist claiming that protections exist.

v 6.3.2

